

NanoAudit - Reporte Tecnico

INFORME TECNICO DE AUDITORIA

=====

Auditor: [31mIng.Ángel G. Castillo G. [0m

Fecha: 2026-02-09 14:21:42

Modulo: Auditoria Red

=====

INFORME DE AUDITORIA DE RED

FECHA: 2023-10-27

CONSULTOR: [Su Nombre/Departamento de Ciberseguridad]

1. ANALISIS TECNICO:

Durante la fase de auditoría de red, se ha identificado la presencia y/o escaneo de los puertos 21 y 80. Es crucial señalar que los datos RAW proporcionados no especifican el estado (abierto/cerrado/filtrado) ni los servicios exactos que se ejecutan en estos puertos. Para los propósitos de este informe, asumiremos que estos puertos fueron encontrados abiertos y respondiendo a conexiones, lo cual es la situación más relevante para una auditoría de seguridad.

* Puerto 21 (FTP - File Transfer Protocol):

Este puerto es comúnmente utilizado para la transferencia de archivos. Si está abierto, indica la presencia de un servidor FTP. Los riesgos asociados a FTP incluyen:

- Transmisión de credenciales (nombres de usuario y contraseñas) y datos en texto claro, lo que facilita la interceptación.

NanoAudit - Reporte Tecnico

- Posibilidad de acceso anónimo o con credenciales débiles.
 - Vulnerabilidades conocidas en versiones desactualizadas de servidores FTP (vsftpd, ProFTPD, Pure-FTPd, etc.).
 - Acceso no autorizado a directorios y archivos.
- * Puerto 80 (HTTP - Hypertext Transfer Protocol):
- Este puerto es el estándar para la comunicación web no cifrada. Si está abierto, indica la presencia de un servidor web (Apache, Nginx, IIS, etc.). Los riesgos asociados a HTTP incluyen:
- Exposición de información sensible a través de la web si no se utiliza HTTPS (puerto 443).
 - Vulnerabilidades en el software del servidor web (versiones desactualizadas, configuraciones inseguras).
 - Vulnerabilidades en aplicaciones web alojadas (SQL Injection, Cross-Site Scripting (XSS), inclusión de archivos, etc.).
 - Divulgación de información (banners de versiones, listado de directorios).
 - Ausencia de cabeceras de seguridad HTTP robustas.

La exposición de estos puertos a la red, especialmente la pública, siempre representa un vector de ataque potencial si no se gestionan y protegen adecuadamente.

2. IMPACTO:

La existencia de puertos abiertos sin una justificación y configuración de seguridad rigurosa representa un riesgo significativo para la organización:

- * Riesgo de Brecha de Datos:
- FTP (Puerto 21): Un atacante podría interceptar credenciales y acceder a archivos sensibles,

NanoAudit - Reporte Tecnico

modificarlos, eliminarlos o exfiltrarlos. Esto puede resultar en robo de propiedad intelectual, información de clientes o datos operativos críticos.

- HTTP (Puerto 80): La falta de cifrado permite a un atacante interceptar cualquier dato transmitido, incluyendo credenciales de usuario, información personal identificable (PII) o datos financieros si la aplicación web no redirige a HTTPS.

* Riesgo de Compromiso del Sistema:

- Vulnerabilidades en los servidores FTP o HTTP (o las aplicaciones web) pueden ser explotadas para obtener acceso no autorizado al servidor subyacente, llevando a la ejecución de código remoto, escalada de privilegios y control total del sistema.

* Riesgo de Interrupción de Servicio:

- Ataques de Denegación de Servicio (DoS) o intrusiones exitosas pueden dejar inoperativos los servicios FTP o web, afectando la continuidad del negocio y la disponibilidad para usuarios internos y externos.

* Riesgo de Daño Reputacional y Legal:

- Una brecha de seguridad resultante de puertos expuestos puede llevar a la pérdida de confianza de clientes y socios, multas por incumplimiento normativo (GDPR, HIPAA, etc.) y litigios.

* Riesgo de Movimiento Lateral y Persistencia:

- Un compromiso inicial a través de estos puertos puede ser utilizado como punto de entrada para explorar la red interna, buscar otros sistemas vulnerables y establecer mecanismos de persistencia.

La combinación de estos riesgos puede llevar a una brecha de seguridad grave, afectando la confidencialidad, integridad y disponibilidad de la información y los servicios críticos de la empresa.

3. SOLUCION:

Para mitigar los riesgos asociados a la exposición de los puertos 21 y 80, se recomiendan las siguientes

NanoAudit - Reporte Tecnico

acciones:

* ACCION INMEDIATA: Verificación y Auditoría Detallada

- Identificar el servicio exacto: Determinar qué aplicación o servicio está escuchando en estos puertos y su versión específica.

- Para Linux: ``sudo netstat -tulnp | grep ":21"`` y ``sudo netstat -tulnp | grep ":80"``
 - Para Windows (PowerShell): ``Get-NetTCPConnection -LocalPort 21`` y ``Get-NetTCPConnection -LocalPort 80``

- Realizar escaneos de vulnerabilidades: Utilizar herramientas como Nmap (para detección de versiones), OpenVAS, Nessus o Burp Suite (para aplicaciones web) para identificar debilidades específicas.

- Revisar configuraciones: Evaluar los archivos de configuración de los servicios (ej. ``vsftpd.conf``, ``httpd.conf``, ``nginx.conf``) para identificar configuraciones inseguras.

* MITIGACION PARA PUERTO 21 (FTP):

- Deshabilitar o Restringir: Si el servicio FTP no es absolutamente necesario, debe ser deshabilitado.

- Comando ejemplo (Linux, si usa systemd): ``sudo systemctl stop <nombre_servicio_ftp>`` y ``sudo systemctl disable <nombre_servicio_ftp>``

- Migrar a SFTP/FTPS: Si la transferencia de archivos es necesaria, migrar a protocolos seguros como SFTP (FTP sobre SSH) o FTPS (FTP sobre SSL/TLS), que cifran tanto las credenciales como los datos. Asegurarse de que FTP no cifrado no esté disponible.

- Autenticación Fuerte: Implementar políticas de contraseñas complejas, rotación regular de contraseñas y, si es posible, autenticación multifactor. Evitar usuarios anónimos.

- Principios de Mínimo Privilegio: Asegurar que las cuentas de usuario FTP tengan acceso solo a los directorios y archivos estrictamente necesarios. Utilizar jaulas ``chroot`` para confinar a los usuarios a sus directorios home.

NanoAudit - Reporte Tecnico

- Actualizaciones y Parches: Mantener el software del servidor FTP actualizado a la última versión para corregir vulnerabilidades conocidas.

- Firewall: Restringir el acceso al puerto 21 solo a direcciones IP de confianza o redes específicas.

- Comando ejemplo (Linux, usando UFW): `sudo ufw deny 21` (para cerrar) o `sudo ufw allow from <IP\_o\_Subred\_Confianza> to any port 21` (para restringir).

* MITIGACION PARA PUERTO 80 (HTTP):

- Migrar a HTTPS (Puerto 443): La acción más crítica es migrar todo el tráfico web a HTTPS utilizando certificados SSL/TLS válidos. Configurar el servidor web para redirigir todo el tráfico HTTP (puerto 80) a HTTPS (puerto 443).

- Configuración ejemplo (Apache):

...

```
<VirtualHost *:80>
```

```
    ServerName midominio.com
```

```
    Redirect permanent / https://midominio.com/
```

```
</VirtualHost>
```

...

- Configuración ejemplo (Nginx):

...

```
server {
```

```
    listen 80;
```

```
    server_name midominio.com;
```

```
    return 301 https://$host$request_uri;
```

```
}
```

...

NanoAudit - Reporte Tecnico

- Deshabilitar HTTP si no es requerido: Una vez que HTTPS esté completamente implementado y funcional, se puede considerar deshabilitar el puerto 80 si no hay necesidad de redirigir.
- Comando ejemplo (Linux, si usa systemd y es un servicio httpd): ``sudo systemctl stop httpd``
- Endurecimiento del Servidor Web:
 - Deshabilitar listado de directorios.
 - Ocultar versiones del servidor y otra información sensible.
 - Implementar cabeceras de seguridad HTTP (ej. Content-Security-Policy, X-Frame-Options, Strict-Transport-Security (HSTS)).
 - Eliminar módulos no utilizados.
 - Parches y Actualizaciones: Mantener el sistema operativo y el software del servidor web (Apache, Nginx, IIS) actualizados.
- Seguridad de Aplicaciones Web: Si se aloja una aplicación, realizar pruebas de seguridad periódicas (SAST/DAST) para identificar y corregir vulnerabilidades.
- Web Application Firewall (WAF): Implementar un WAF para proteger las aplicaciones web de ataques comunes (SQLi, XSS, etc.).
- Firewall: Restringir el acceso al puerto 80/443 a la red pública o a balanceadores de carga/WAFs si están en uso.

* MEDIDAS DE SEGURIDAD GENERALES:

- Gestión de Parches: Implementar un proceso robusto para mantener todos los sistemas operativos y software actualizados.
- Segmentación de Red: Aislar los servidores que exponen estos puertos en segmentos de red dedicados (DMZ) para limitar el impacto en caso de compromiso.
- Monitoreo y Registro (Logging): Configurar la auditoría y el registro de eventos en los servidores FTP y Web, y centralizar estos logs en un SIEM (Security Information and Event Management) para la detección

NanoAudit - Reporte Tecnico

temprana de actividades sospechosas.

- Respuesta a Incidentes: Disponer de un plan de respuesta a incidentes bien definido y probado.
- Concienciación: Capacitar al personal sobre las mejores prácticas de seguridad.

La implementación de estas soluciones reducirá significativamente la superficie de ataque y el riesgo asociado a los puertos 21 y 80, fortaleciendo la postura de ciberseguridad de la organización.

=====